

O que realmente está exposto?

Missão: investigar uma exposição simples no Juice Shop local e produzir um registro que conecte ativo, fraqueza, vetor, consequência, controle e reteste.

Duração	Organização	Entrega
52 minutos	duplas; papéis rotativos	um PDF por dupla

Objetivos

- Inventariar ativos de TI e OT relacionando função e consequência.
- Distinguir ameaça, fraqueza, vulnerabilidade, exposição e exploit na evidência.
- Priorizar o registro, escolher controle e definir validação reproduzível.

Pré-requisitos e recursos

- A01 e página MkDocs A02 consultável durante a atividade.
- Juice Shop local no endereço informado pelo professor.
- Navegador com DevTools; Burp Community é opcional.
- Este roteiro contém evidência alternativa para falha do ambiente.

ATENÇÃO

Escopo: somente o Juice Shop local fornecido. Não teste a demonstração pública, sistemas institucionais ou terceiros. Use dados fictícios. Pare se o destino divergir, houver dados reais ou o comportamento alcançar outro sistema.

Hipótese inicial

Antes de executar, registre qual recurso pode estar exposto, por que isso seria possível e qual resposta confirmaria ou refutaria sua hipótese.

Hipótese: _____

Evidência esperada: _____

Etapa 1 — Preparar e verificar (8 min)

- Copie do quadro o endereço exato do alvo local; confirme protocolo, host e porta.
- Abra a página inicial e registre somente versão/identificação exibida sem dados sensíveis.
- Definam papéis: investigador opera; revisor confere escopo e anota. Troquem depois da Etapa 2.
- Se a página não abrir ou o destino não for o indicado, use a evidência alternativa e não improvise.

EVIDÊNCIA

Estado inicial: alvo sanitizado, horário relativo e confirmação de que a página inicial responde. Não capture credenciais, tokens, cookies ou IP público.

Etapa 2 — Observar sem enumerar (12 min)

Com DevTools na aba Network, observe uma requisição orientada pelo professor. Execute uma tentativa por vez. Registre método, caminho relativo, status, tipo de conteúdo e o que a resposta demonstra. Não use scanner, força bruta ou lista de caminhos.

ALTERNATIVA

Se o ambiente falhar, use: GET /ftp/acquisitions.md → HTTP/1.1 200 OK, Content-Type: text/markdown. Trate-a como evidência fictícia; não presuma conteúdo que não foi mostrado.

PISTA

Um código 200 comprova que o servidor entregou o recurso naquela requisição. Ele não prova sozinho a causa, a autoria, o alcance nem a consequência.

Etapa 3 — Inventariar e interpretar (12 min)

Preencha ao menos quatro linhas. Inclua o recurso observado, a aplicação, a plataforma e um ativo OT de transferência.

Ativo/tipo	Função/proprietário	Consequência	Prioridade e evidência

Etapa 4 — Registrar a vulnerabilidade (10 min)

Descreva comportamento esperado e observado. Relacione: ativo; ameaça plausível; fraqueza provável; vulnerabilidade concreta; caminho de exposição; técnica necessária; consequência; limites da hipótese. Não invente um CVE.

Campo	Registro da dupla
Evidência reproduzível e interpretação	
Fraqueza provável e lacuna	
Vetor/ameaça dentro do escopo	
Consequência e prioridade	
Limites e próxima evidência	

DECISÃO
Escolha uma prioridade pela consequência, não pela obtenção de uma flag. Explique o que mudaria a prioridade.

Etapa 5 — Tratar e validar (10 min)

Compare as opções e recomende uma conforme a função do recurso.

Opção	Melhor uso	Evidência/entrega	Limitação/risco
Remover da área pública	recurso não deve ser servido	rota negada e publicação revisada	pode quebrar dependência
Autorizar no servidor	papel precisa acessar	casos permitido e negado	política incorreta
Reduzir conteúdo	publicação é necessária	somente dados necessários	não corrige outras rotas
Detectar acessos	correção não imediata	log/alerta testado	não impede exposição

Controle escolhido e premissa: _____

Reteste e resultado esperado: _____

Entrega

Envie no Google Classroom um PDF chamado A02-dupla-NN.pdf com: hipótese inicial; inventário priorizado; uma evidência interpretada; registro de vulnerabilidade; controle e reteste; reflexão de até cinco linhas. Uma captura sem interpretação não conta como evidência.

Critérios de sucesso

Critério	Atendeu	Parcial
Inventário	ativos, função, proprietário e consequência	lista sem priorização
Precisão	termos distintos e limites explícitos	mistura termos ou afirma causa
Evidência	reproduzível, sanitizada e interpretada	captura pouco explicada
Tratamento	controle ligado à causa e reteste	controle genérico
Conduta	escopo e parada respeitados	registro incompleto

Limpeza e encerramento

- Feche DevTools e descarte capturas que contenham cookies, tokens ou dados não sanitizados.
- Se você iniciou o Juice Shop, encerre o processo ou container pelo procedimento informado.
- Confirme que a porta do serviço vulnerável não ficou acessível fora do laboratório.
- Preserve somente o PDF sanitizado da entrega.

Extensão opcional

Proponha uma consulta de inventário que encontraria exposições semelhantes sem varrer redes ou testar terceiros. Indique fonte dos dados, responsável e critério de atualização.

Transferência

Em uma HMI industrial, qual consequência física e qual janela de manutenção mudariam a escolha entre remover, autorizar e monitorar?

Fontes oficiais

- NIST CSF 2.0 — <https://doi.org/10.6028/NIST.CSWP.29>
- CVE Program — <https://www.cve.org/>
- CWE — <https://cwe.mitre.org/>
- OWASP Juice Shop — <https://owasp.org/www-project-juice-shop/>